Lecture 2.2: IAM

Maharishi International University

Department of Computer Science

M.S. Thao Huy Vu

Maharishi International University - Fairfield, Iowa

All rights reserved. No part of this slide presentation may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying or recording, or by any information storage and retrieval system, without permission in writing from Maharishi International University (MIU).

Agenda

- IAM Roles and Cross-Account Access
- Identity Providers and Federation
- Advanced Policy Management
- Monitoring and Auditing IAM Activities

IAM Roles

- Identity: An IAM role is an IAM identity that is created with specific permissions.
- Assumable: It is intended to be assumable by anyone who needs it.
- Temporary Credentials: Roles provide temporary security credentials for users or services that need to perform specific tasks.
- Separation of Permissions: Roles help separate permissions from users and can be assumed by trusted entities within or outside the AWS account.

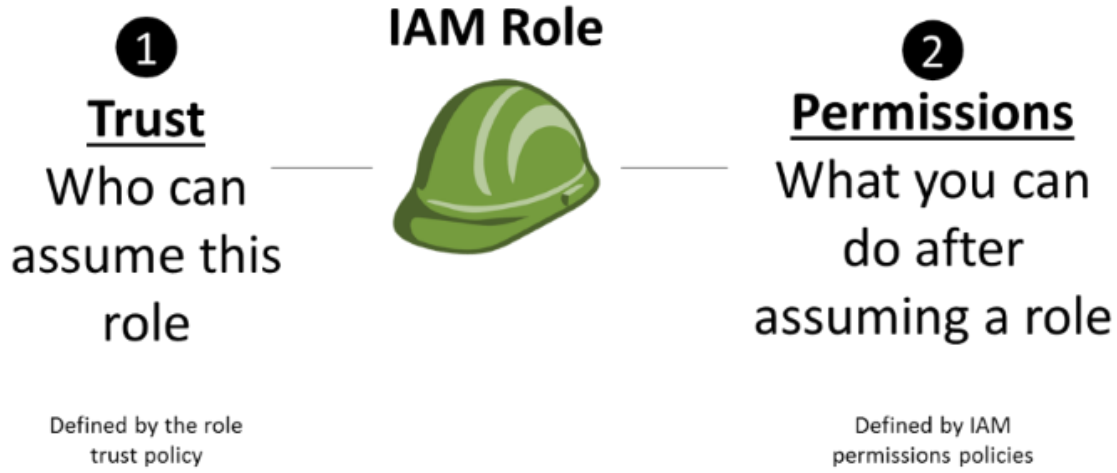
IAM roles

- Components:
  - Trust Policy: Defines who is allowed to assume the role
  - Permission Policy: Defines what actions and resources the role has access to
- Common Use Cases:
  - EC2 Instance Roles: Allow EC2 instances to access AWS services
  - Cross-Account Access: Allow users from one AWS account to access resources in another account
  - Service Roles: Allow AWS services like Lambda or ECS to access other AWS services

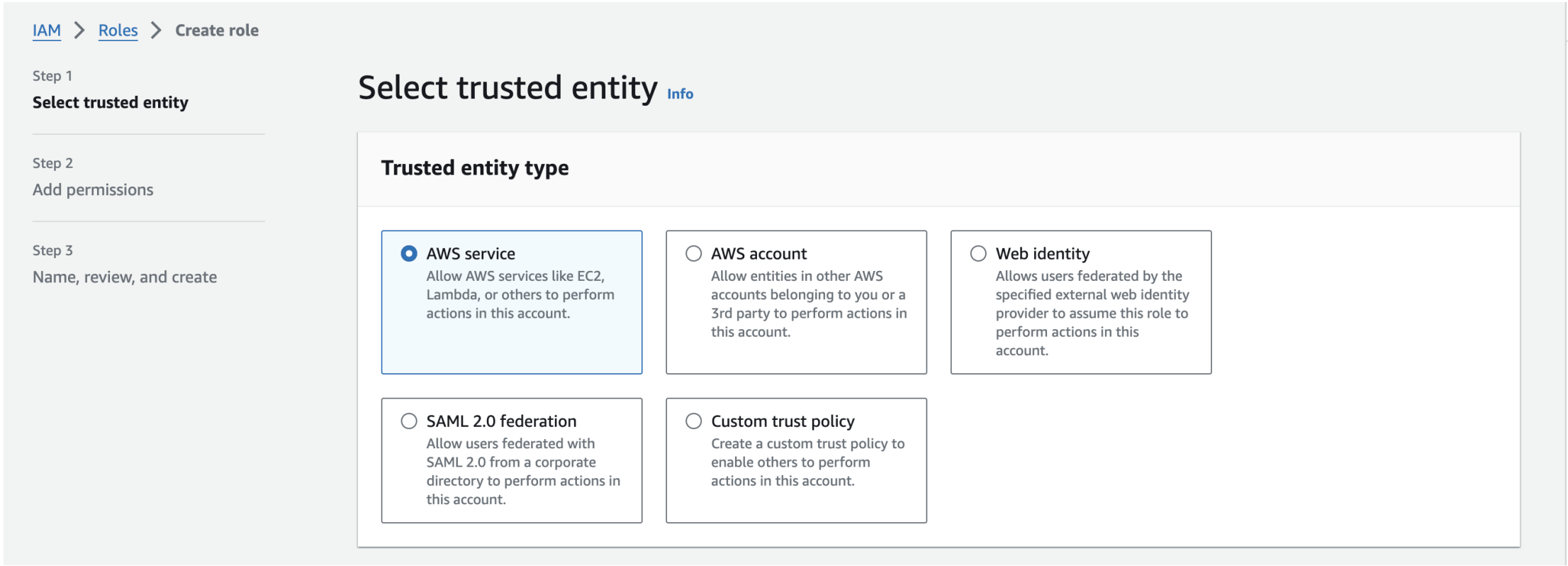
IAM role

An IAM user and role have one thing in common, permission policies.

When the service in the trust policy assumes the role, AWS STS (Security Token Service) returns **temporary** tokens (access key id, secret access key, and **session token**), and those tokens are rotated automatically.



IAM Roles


IAM > Roles > Create role
Step 1
Select trusted entity
Step 2
Add permissions
Step 3
Name, review, and create
Select trusted entity Info
Trusted entity type
AWS service
Allow AWS services like EC2, Lambda, or others to perform actions in this account.
AWS account
Allow entities in other AWS accounts belonging to you or a 3rd party to perform actions in this account.
Web identity
Allows users federated by the specified external web identity provider to assume this role to perform actions in this account.
SAML 2.0 federation
Allow users federated with SAML 2.0 from a corporate directory to perform actions in this account.
Custom trust policy
Create a custom trust policy to enable others to perform actions in this account.

AWS Security Token Service (AWS STS)

Under the hood, tokens are generated and used to access AWS services. STS is a web service that enables you to request **temporary** credentials for IAM role.

The temporary credentials consist of:

1. **Access key ID** - Access keys are long-term credentials for an IAM user. Like username.
2. **Secret access key** - Like password.
3. **Session token** - Validates temporary credentials.
4. **Duration** - defines how long the temporary credentials lasts. Most cases 12 hours. 15-min is min. You will not see these in the permanent tokens for users.

STS - AssumeRole

The underlying service makes an implicit “AssumeRole” call to STS on behalf of the resource and fetch the temporary tokens. It all happens under the hood.

For instance, when fetching images from S3 in EC2, EC2 makes the AssumeRole call to STS, then receives the token and provides the token to S3. You don’t have to manually rotate it. The rotation is done by AWS.

IAM User vs Role

IAM User	**IAM Role**
IAM entity assigned to a **person**.	IAM entity assigned to another **service**. It has a trust policy that specifies what services can use the role.
Tokens are permanent. Not recommended.	**Tokens are temporary**. Tokens are generated by AWS STS. It has an extra token “aws_session_token”.
Not a good practice. Feasible for single user accounts and a small team in 10	Federated users are a practical approach that uses IAM role and STS to get access to AWS

Identity Providers and Federation

- Identity Provider (IdP): A service that creates, maintains, and manages identity information for principals (users or services) and provides authentication services to relying applications within a federation or distributed network
- Federation: The process of establishing trust relationships between different identity domains, allowing users from one domain to access resources in another domain without needing to create separate accounts.

Identity Providers and Federation

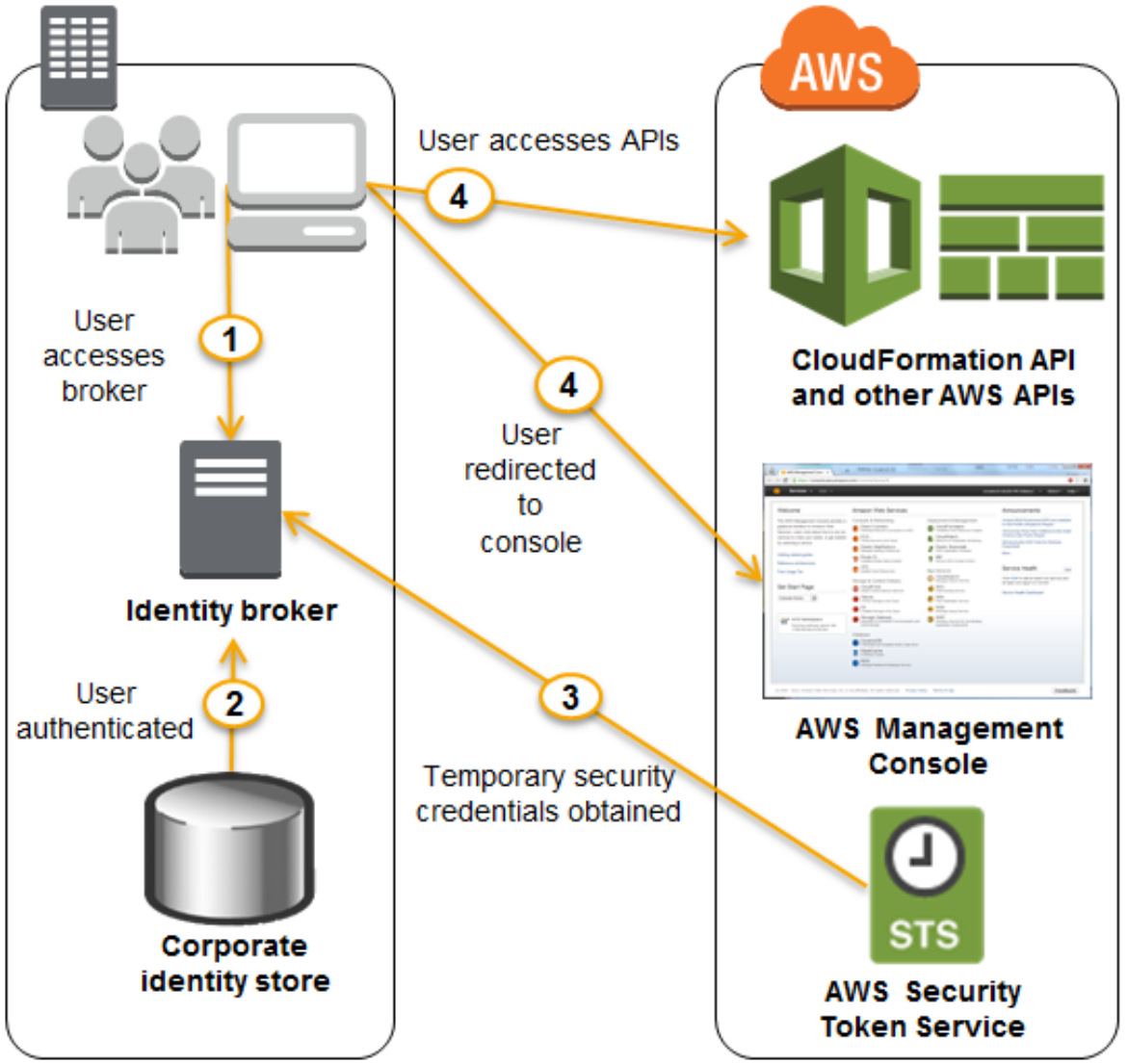
- Purpose
  - Single Sign-On (SSO): Enables users to sign in once and access multiple systems, including AWS, without needing multiple credentials
  - Centralized Identity Management: Allows organizations to manage user identities and access from a central directory, such as Microsoft Active Directory, Google, or other third-party identity providers.
- Use cases
  - Enterprise Integration: Integrate AWS with corporate directories for seamless access
  - Partner Access: Grant temporary access to external partners using their own credentials
  - SSO Solutions: Implement SSO for internal applications and AWS resources

Identity federation

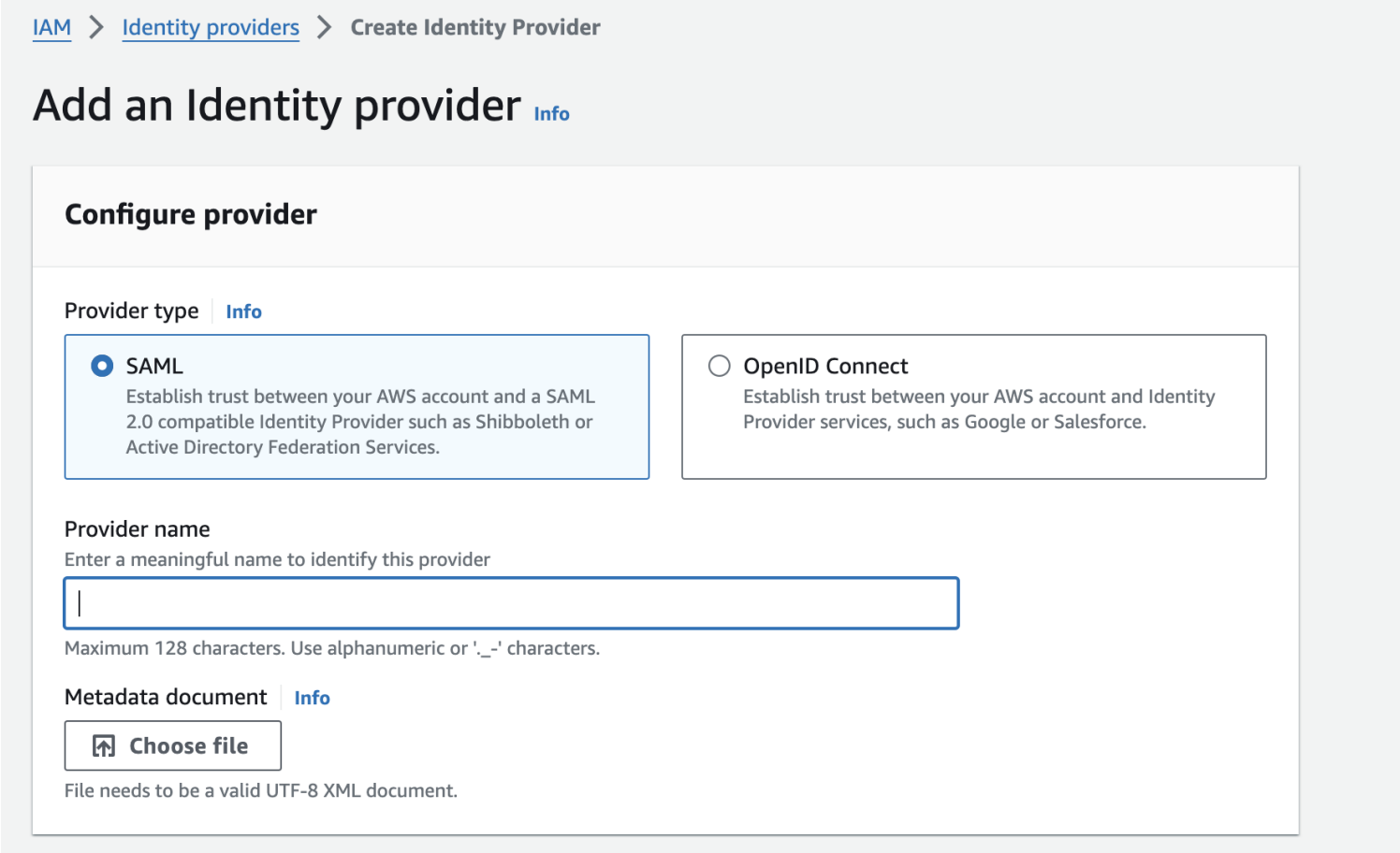
Identity federation grants external identities secure access to resources in your AWS account. These external identities can come from your corporate identity provider such as Microsoft Active Directory.

Federated users (external identities) are users you manage outside of AWS in your corporate directory, but to whom you grant access to your AWS account using **temporary security credentials** (Role and STS).

Federated users and temporary security credentials STS



Identity Providers and Federation



Advanced Policy Management

- Advanced IAM Policies: Policies that go beyond basic allow/deny permissions to include conditions, resource-specific permissions, and version control
- Allows for fine-grained access control, improving security and adherence the principle of least privilege
- Enables the use of conditions to dynamically adjust permissions based on factors such as time, IP address, or multi-factor authentication (MFA).

Advanced Policy Management

- Conditions allow to specify when a policy is in effect, using key-value pairs to control access dynamically.
- Use cases
  - Restricting Actions by IP: Allowing access only from specific IP ranges.
  - Time-based Access: Granting access during specific times or days.
  - Resource-level permissions: Specifying permissions for particular resources or subsets of resources.

Advanced Policy Management

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*",
      "Condition": {
        "IpAddress": {
          "aws:SourceIp": "203.0.113.0/24"
        }
      }
    }
  ]
}
```

Advanced Policy Management

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:ListBucket"
      ],
      "Resource": [
        "arn:aws:s3:::example-bucket",
        "arn:aws:s3:::example-bucket/*"
      ]
    }
  ]
}
```

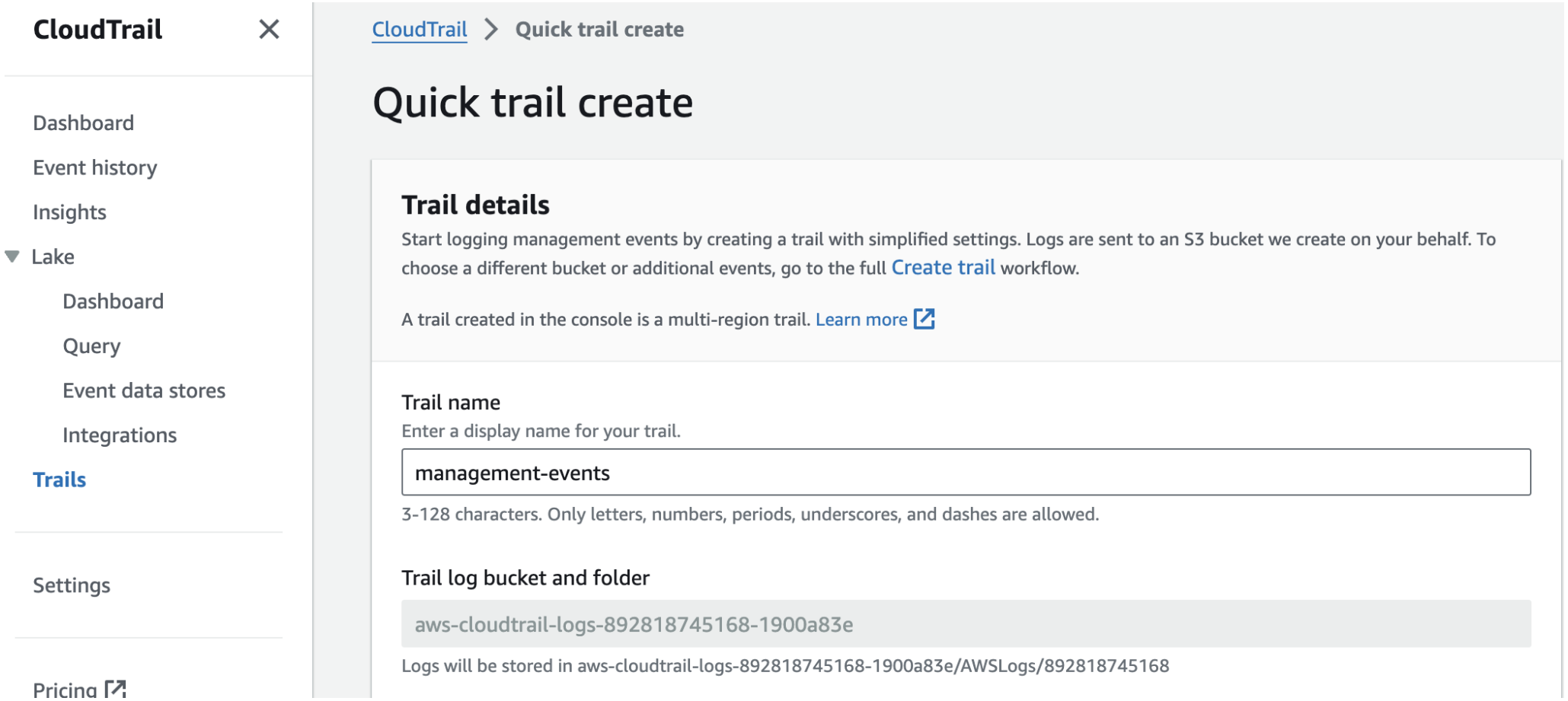
Monitor and Audit IAM Activities

- Monitoring: Continuous tracking of user activities and API calls to detect and respond to security threats.
- Auditing: Systematic review of user activities and resource configurations to ensure compliance with security policies and standards.
- Purpose:
  - Security: Detect unauthorized access or misconfigurations that could lead to security breaches
  - Compliance: Ensure adherence to regulatory requirements and internal policies
  - Accountability: Maintain detailed records of user actions for accountability and troubleshooting

AWS CloudTrail

- A service that logs, monitors, and retains account activity related to actions across AWS infrastructure.
- Key Features:
  - Event History: Provides a history of AWS API calls for your account, including API calls made through the AWS Management Console, AWS SDKs, command-line tools, and other AWS services
  - Trail Configuration: You can create a trail to deliver log files to an Amazon S3 and integrate with CloudWatch Logs.

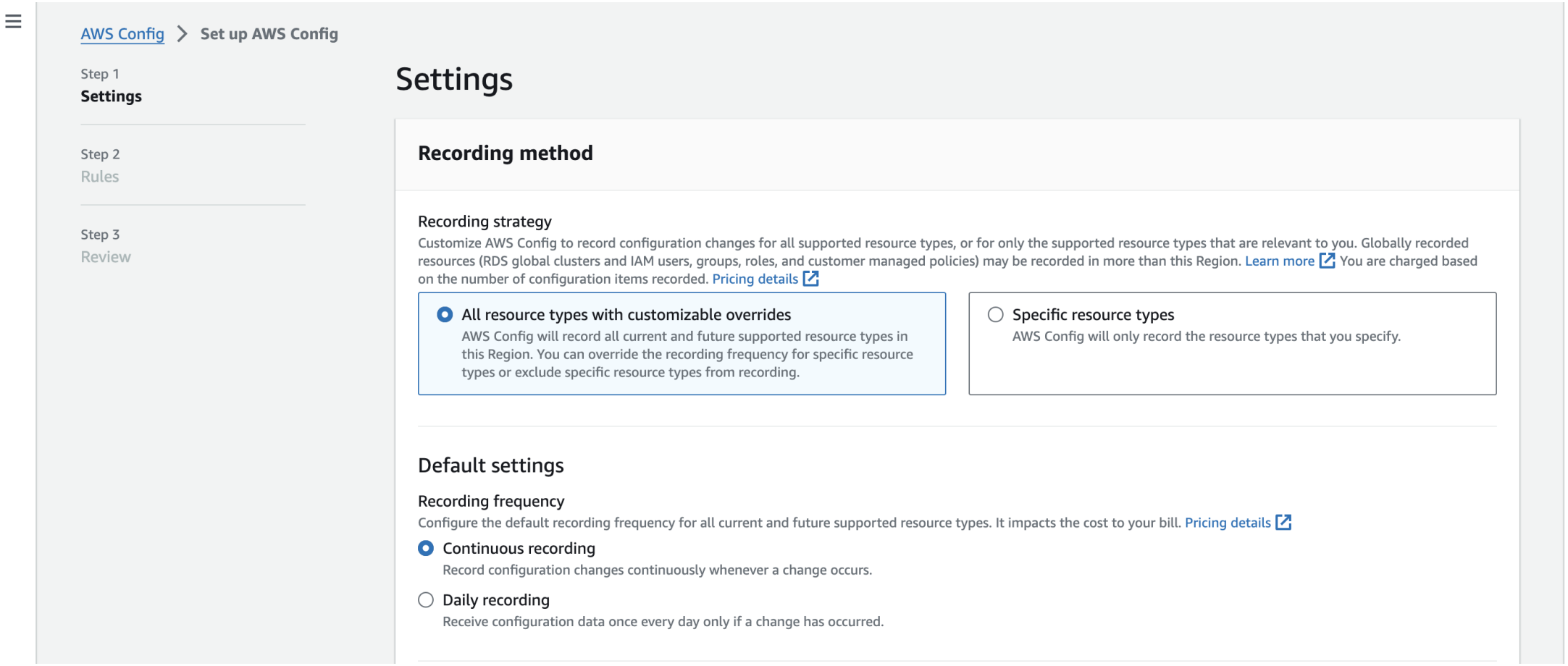
AWS CloudTrail



AWS Config

- AWS Config: A service that enables you to assess, audit, and evaluate the configurations of your AWS resources. AWS Config continuously monitors and records your AWS resource configurations and allows you to automate the evaluation of recorded configurations against desired configurations.
- Key features:
  - Configuration History: Provides a detailed view of the configuration of AWS resources over time.
  - Compliance Management: Automates the evaluation of resource configurations against compliance rules.

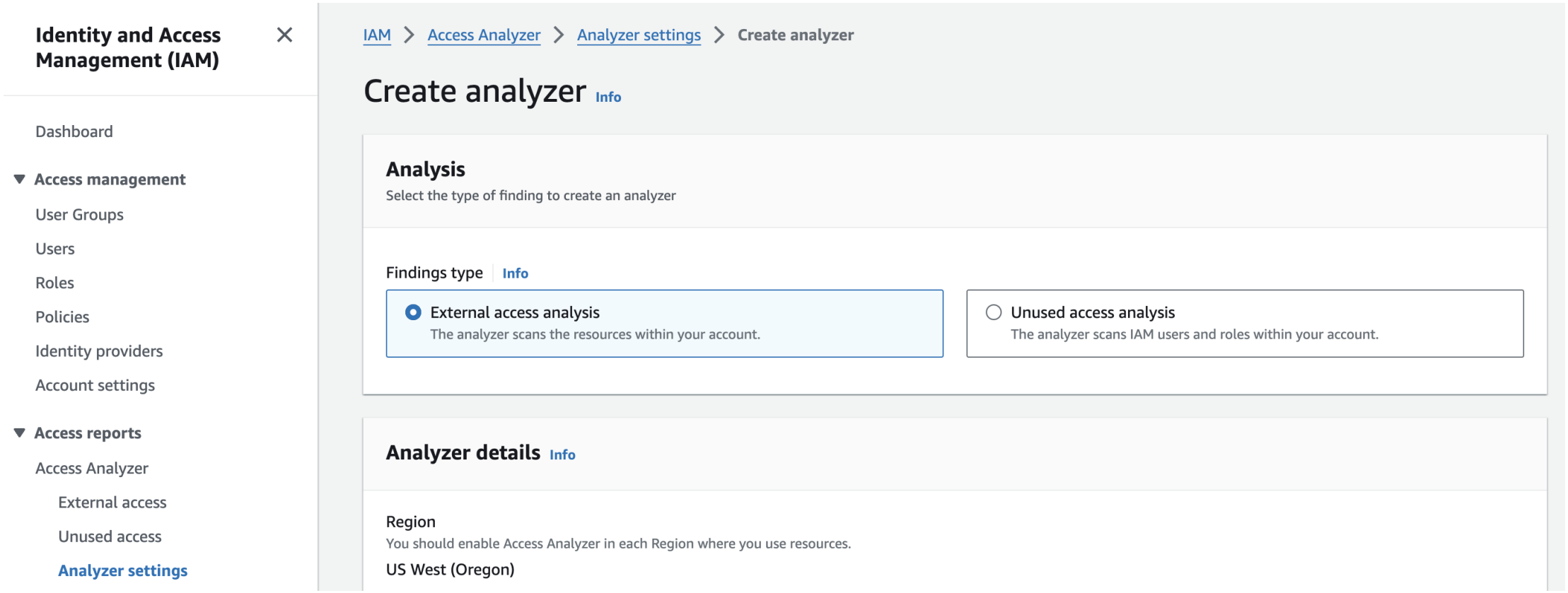
AWS Config


AWS Config > Set up AWS Config
Step 1
Settings
Step 2
Rules
Step 3
Review
Settings
Recording method
Recording strategy
Customize AWS Config to record configuration changes for all supported resource types, or for only the supported resource types that are relevant to you. Globally recorded resources (RDS global clusters and IAM users, groups, roles, and customer managed policies) may be recorded in more than this Region. Learn more You are charged based on the number of configuration items recorded. Pricing details
All resource types with customizable overrides
AWS Config will record all current and future supported resource types in this Region. You can override the recording frequency for specific resource types or exclude specific resource types from recording.
Specific resource types
AWS Config will only record the resource types that you specify.
Default settings
Recording frequency
Configure the default recording frequency for all current and future supported resource types. It impacts the cost to your bill. Pricing details
Continuous recording
Record configuration changes continuously whenever a change occurs.
Daily recording
Receive configuration data once every day only if a change has occurred.

IAM Access Analyzer

- IAM Access Analyzer: helps you identify the resources in your organization and accounts, such as Amazon S3 buckets or IAM roles, that are shared with an external entity. It continuously monitors and logs findings for new and updated policies.
- Key features:
  - Policy Analysis: Analyzes IAM policies to identify permissions granted to external entities
  - Continuous Monitoring: Automatically updates findings when there are changes to resource policies.

IAM Access Analyzer



AWS CLI

- AWS Command Line Interface (AWS CLI) is a unified tool to manage AWS services.
- Installation: https://docs.aws.amazon.com/cli/latest/userguide/getting-started-install.html

AWS CLI

- Common commands

aws configure
aws --version
aws iam list-users
aws s3 ls
aws ec2 describe-instances
aws lambda list-functions
aws apigateway get-rest-apis
aws rds describe-db-instances
aws docdb describe-db-clusters

IAM Summary

1. allow/deny
2. What actions?
3. On which resources?
4. Who?
   - principle propriety (resource-based)
   - IAM user or role (identity-based)
5. Condition (optional)

References

- https://docs.aws.amazon.com/
- ChatGPT: https://chatgpt.com/
- Google AI: https://gemini.google.com/app